# 14 — Data breach procedure

*Français (version de référence) : ../fr/14-procedure-violation-donnees.md*

| Header | |
|---|---|
| Publisher | Nhill Solution, Kinshasa (Democratic Republic of the Congo) |
| Version | 3.0.0 — 28 October 2026 |
| Status | internal document; written without review by a lawyer; deadline and content of the notification to the authority to be confirmed (V-06, 00 § 5). The French version is the reference text |
| Assumptions | H-03, H-05, H-15, H-19 (00 § 2) |
| Reference | DRC law (Digital Code, Book III); the GDPR's 72-hour deadline is used as a reference for good practice |

## 1. Definition

Data breach: any security incident leading, accidentally or unlawfully, to the destruction, loss, alteration, disclosure of or unauthorised access to personal data (examples: exposed database, compromised administrator account, lost backup, sending to the wrong recipient, ransomware).

## 2. Roles

The roles are held by people appointed by Nhill Solution's management; the up-to-date list of names (holder and deputy for each role) is kept with the incident register.

| Role | Task |
|---|---|
| Incident lead | decides, coordinates, keeps the register; by default, management |
| Technical | contains the incident on the server and the database, preserves the traces |
| Communication | informs the businesses and people concerned |
| Legal adviser | qualifies the breach and the notification to the authority |

## 3. Steps and deadlines

| Deadline (from detection) | Action |
|---|---|
| immediately | record the time of detection in the incident register; alert the incident lead |
| under 4 hours | contain: cut the compromised access, revoke sessions (per business or globally), change the secrets concerned (`NH_SECRET_KEY` only if necessary: see its consequences in the configuration guide), preserve the logs (`journalctl -u nhill-server`, audit log) |
| under 24 hours | assess: data and people concerned, businesses affected, risk for individuals; **inform the businesses concerned** (Nhill Solution is their processor, document 06) |
| under 72 hours | **notify the competent data protection authority** for the processing Nhill Solution is responsible for, if the breach presents a risk; businesses notify for their own processing, with Nhill Solution's help |
| without undue delay | inform the people concerned if the risk is high, in plain language: what happened, consequences, measures taken, advice, contact |

| Deadline (from detection) | Action |
|---|---|
| under 30 days | root-cause analysis, fixes, test, report; update of the security audit |

## 4. Content of the notification to the authority

Nature of the breach; categories and approximate number of people and records; contact for further information; likely consequences; measures taken or planned. If not everything is known, notify what is known and complete later. The competent authority and how to reach it are checked by the legal adviser at the time of the incident (H-05).

## 5. Incident register

Every incident, even if not notified, is recorded with the following columns:

| Detection date | Description | Data and people | Risk | Measures | Notification to the authority (date) | People informed (date) | Closure |
|---|---|---|---|---|---|---|---|

## 6. Exercise

Simulate an incident once a year (for example: loss of a backup) and measure the actual times.